

FIREWALLS, ACLS & NETWORK SECURITY

KAVINGA YAPA ABEYWARDENA



HAVE YOU EVER BEEN REFUSED ENTRY TO A PARTY?

AGENDA FOR TODAY

- Firewall
- Access Control Lists (ACLs)
  - Simple Packet Filtering
  - Stateful Packet Filtering
- Firewall Topologies

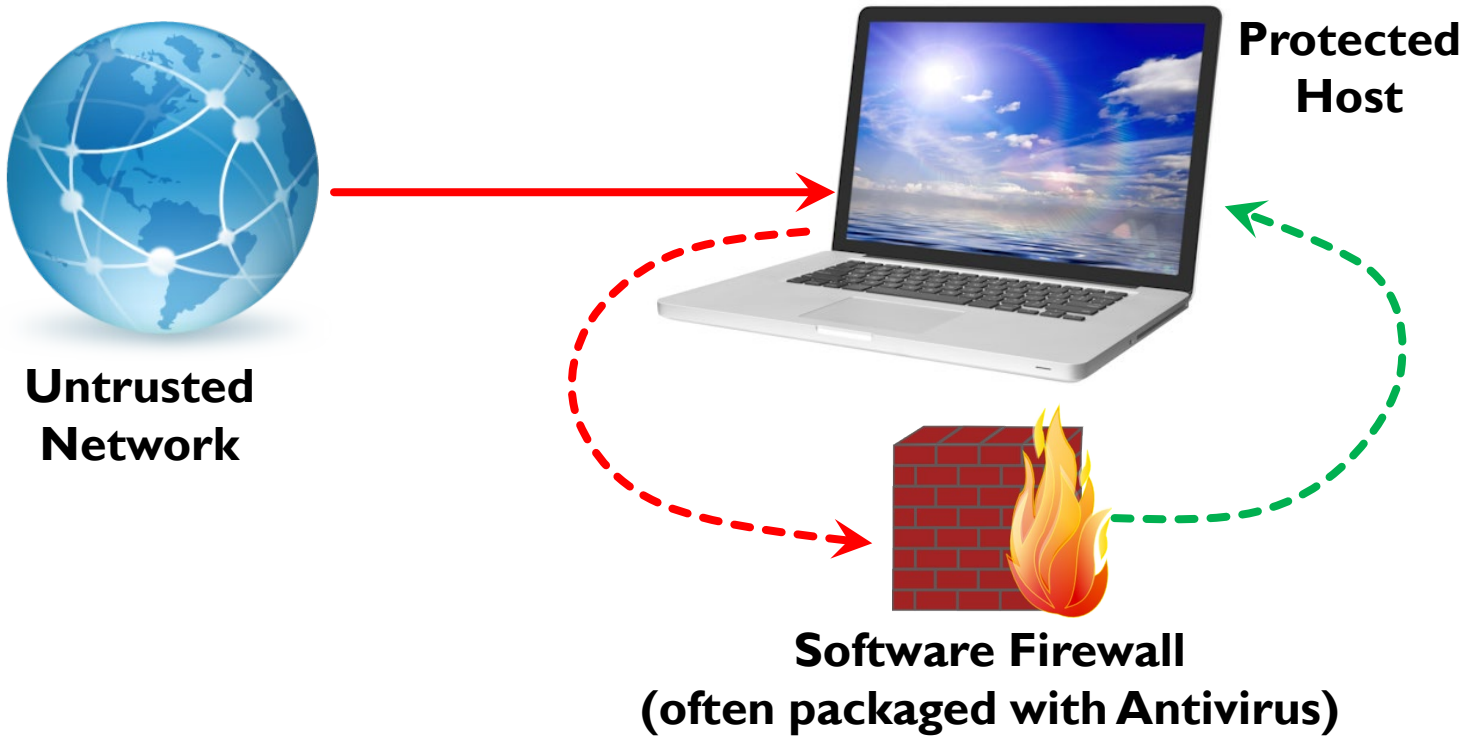


FIREWALL

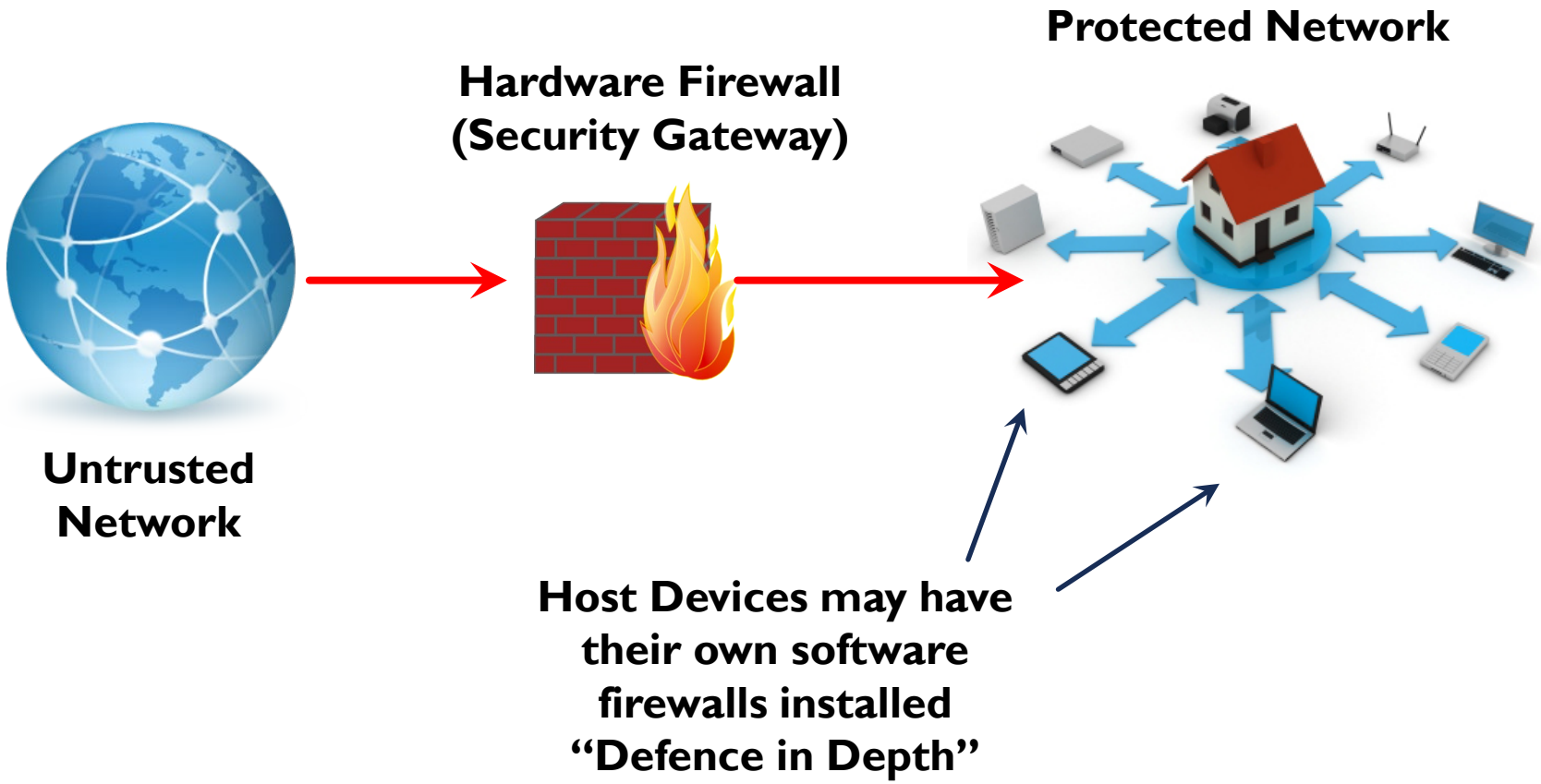
PART I

FIREWALL

- An Electronic "Checkpoint" between a (relatively) protected network/device and a (relatively) untrusted network.



FIREWALL


Protected Network
Hardware Firewall
(Security Gateway)
Untrusted
Network
Host Devices may have
their own software
firewalls installed
"Defence in Depth"

FIREWALL



- A system designed to prevent unauthorized access **to** or **from** a private network. Can be implemented in either hardware or software form, or a combination of both.
- "Setting up a firewall without a comprehensive security policy is like placing a steel door on a tent"

FIREWALL FUNCTIONS

- **"Primary" Functions**
  - Packet Filtering (Layers 3 and 4)
  - Stateful Inspection (Layers 3 and 4)
  - Application Layer Inspection

  } Using Access Control Lists (ACLs)

- **"Secondary" Functions**
  - Network Address Translation (NAT)
  - VPN Tunnelling
  - Proxy Server

PACKET FILTERING

PART 2



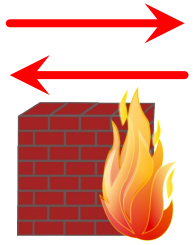
PACKET FILTERING

- Packet Filtering Firewalls can be based on
  - Source/Destination IP Address
  - Source/Destination Port Number
- Can specifically Permit/Deny
- Routers with additional functionality can also perform packet filtering
- Compares IP header with an Access Control List (ACL) to see if packet allowed to continue to next hop
- Inexpensive, flexible and fast

PACKET FILTERING USING ACL

- Apply an **A**ccess **C**ontrol **L**ist to a specific interface
- Applied either **IN** or **out**
- One rule – one line
- Criteria checked sequentially
- Implicit deny at end (usually)
  - Clean Up Rule
- Protect firewall itself
  - Stealth Rule (usually first rule in list)
- Lines appear in order they are entered

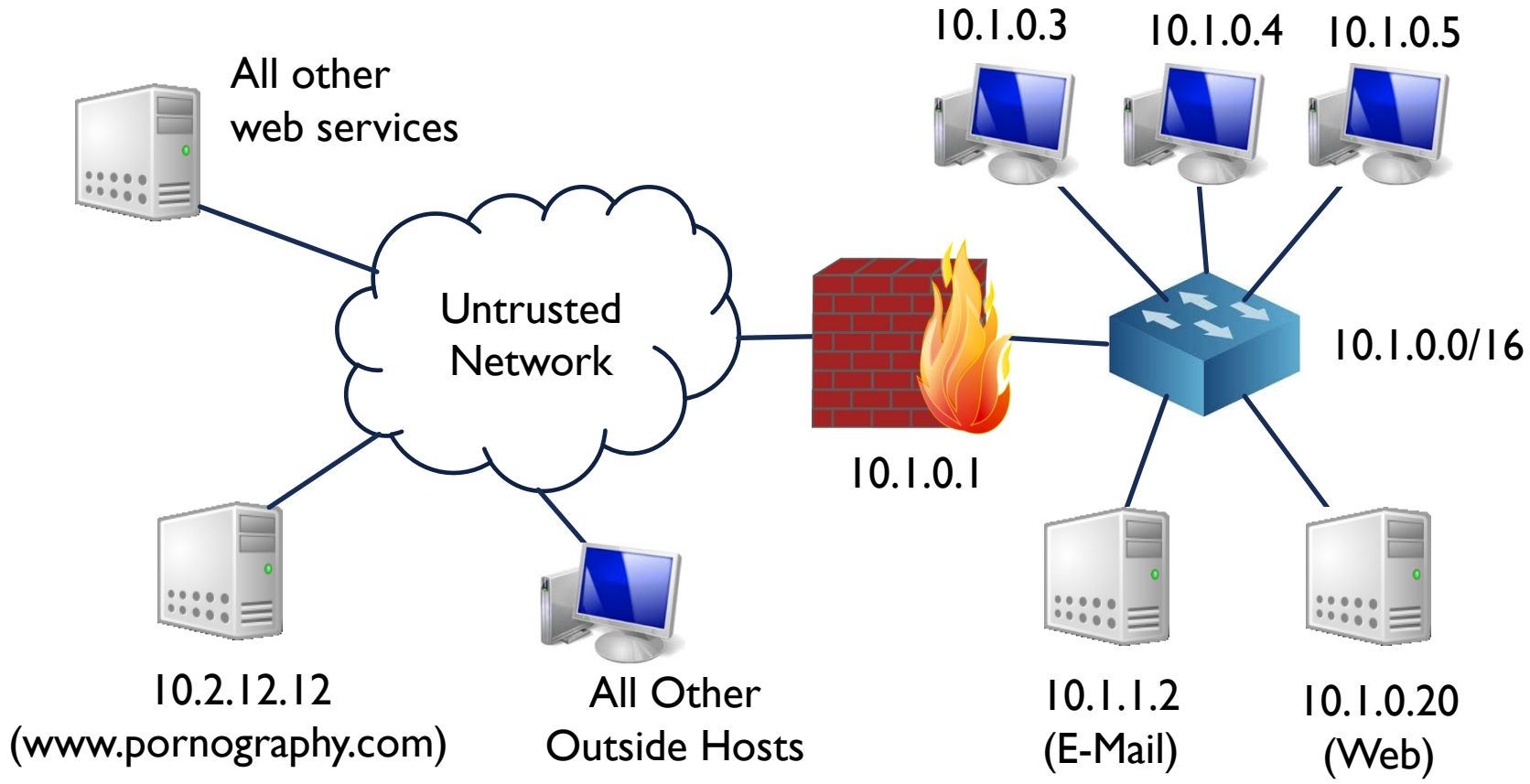






CASE STUDY

The firewall protects subnet 10.1.0.0 /16. Internal hosts may access all external websites except 10.2.12.12. All external hosts may upload E-mail to 10.1.1.2 and access web pages on 10.1.0.20. All other activity is to be blocked. No connection may be made to the firewall itself.



Firewall Address (Stealth Rule)

Rule	Source IP	Source Port	Dest. IP	Dest. Port	Protocol	Access
A	*	*	10.1.0.1	*	*	Deny
B	10.1.0.0	*	10.2.12.12	*	*	Deny
C	10.1.0.0	*	*	80	TCP	Allow
D	*	80	10.1.0.0	*	TCP	Allow
E	*	*	10.1.1.2	25	TCP	Allow
F	10.1.1.2	25	*	*	TCP	Allow
G	*	*	10.1.0.20	80	TCP	Allow
H	10.1.0.20	80	*	*	TCP	Allow
I	*	*	*	*	*	Deny

Cleanup Rule

Port 25 – SMTP (E-Mail Upload)
Port 80 – HTTP (Web)

ACL BEST PRACTICES

- Don't forget protocols are usually bidirectional
  - Common mistakes include blocking return channel
- Reject all external packets that have internal addresses
  - Tunnelled attacks
- Reject all internal packets with external addresses
  - IP Spoofing attacks
- Log and don't respond to dropped packets
- Protect the protection system itself
  - "Stealth" rule – usually first in the list
- Deny everything that is not specifically allowed
  - "Cleanup" rule – sometimes included automatically

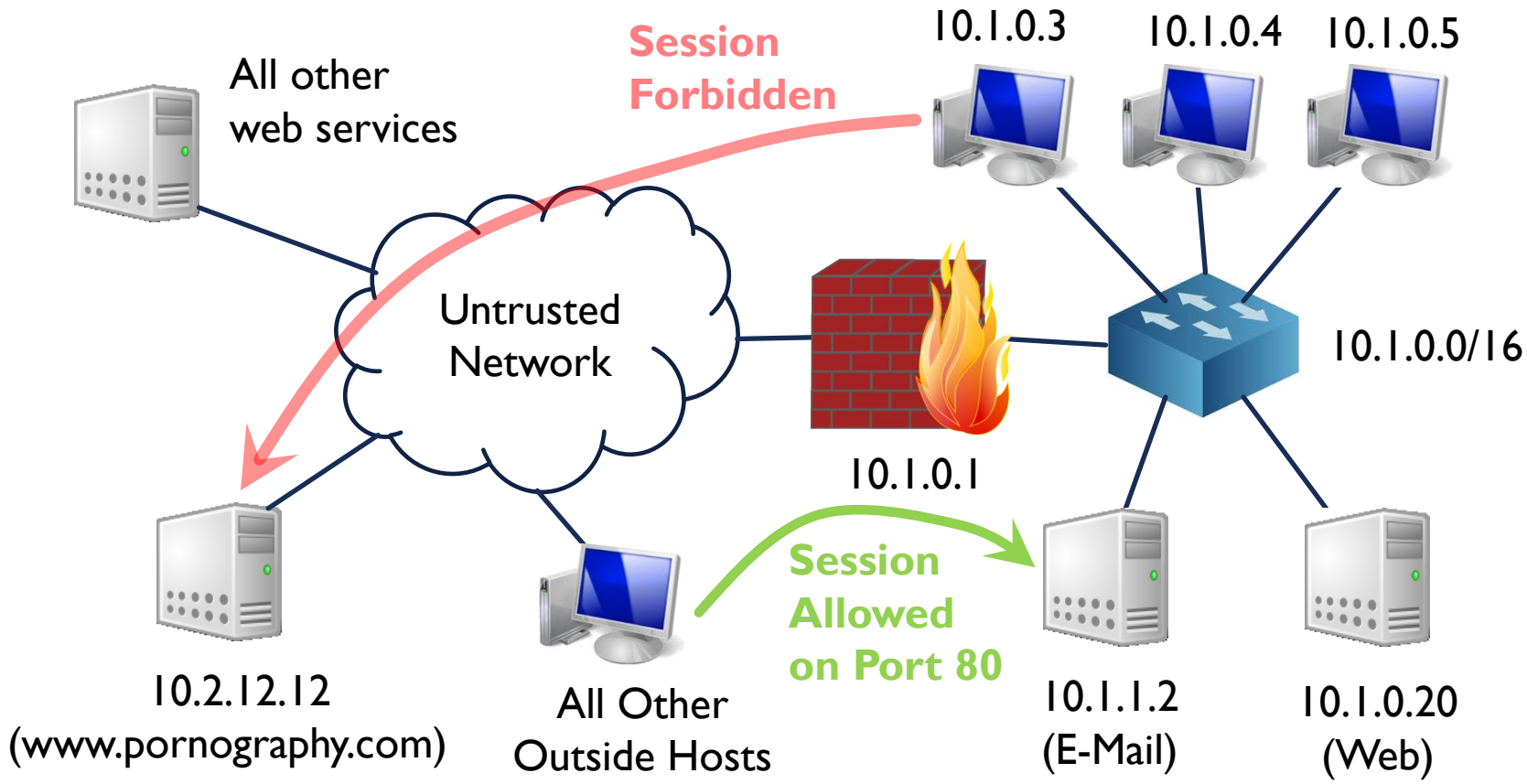
PACKET FILTERING LIMITATIONS

- Cannot keep track of sessions
- Cannot prevent IP Spoofing attacks
- A lot of applications dynamically allocate port numbers, which can cause problems
  - Both sides of a TCP connection can have random high-value port numbers.
- Although TCP traffic is difficult to deal with, UDP traffic is even harder
- Difficult and lengthy to configure
- Better Solution → Stateful Packet Inspection

STATEFUL PACKET INSPECTION

- Inspects packets and allows them if they belong to authorized sessions
  - Allowed sessions specified in stateful ACL
- Example:
  - Allow all packets belonging to "outgoing" connections
    - Sessions initiated from within the secure network
    - SYN packet allowed out but not in.
    - Returning ACK packet only allowed in response to SYN
    - Once session established, packets allowed even if server port is dynamically changed
  - Similarly incoming sessions allowed to particular hosts and ports
  - All other incoming traffic denied

STATEFUL ACL EXAMPLE



Firewall Address (Stealth Rule)

Rule	Source IP	Source Port	Dest. IP	Dest. Port	Protocol	Access
A	*	*	10.1.0.1	*	*	Deny
B	10.1.0.0	*	10.2.12.12	*	*	Deny
C	10.1.0.0	*	*	80	TCP	Allow
D	*	*	10.1.1.2	25	TCP	Allow
E	*	*	10.1.0.20	80	TCP	Allow
F	*	*	*	*	*	Deny

Cleanup Rule

Port 25 – SMTP (E-Mail)
Port 80 – HTTP (Web)

FIREWALL BENEFITS

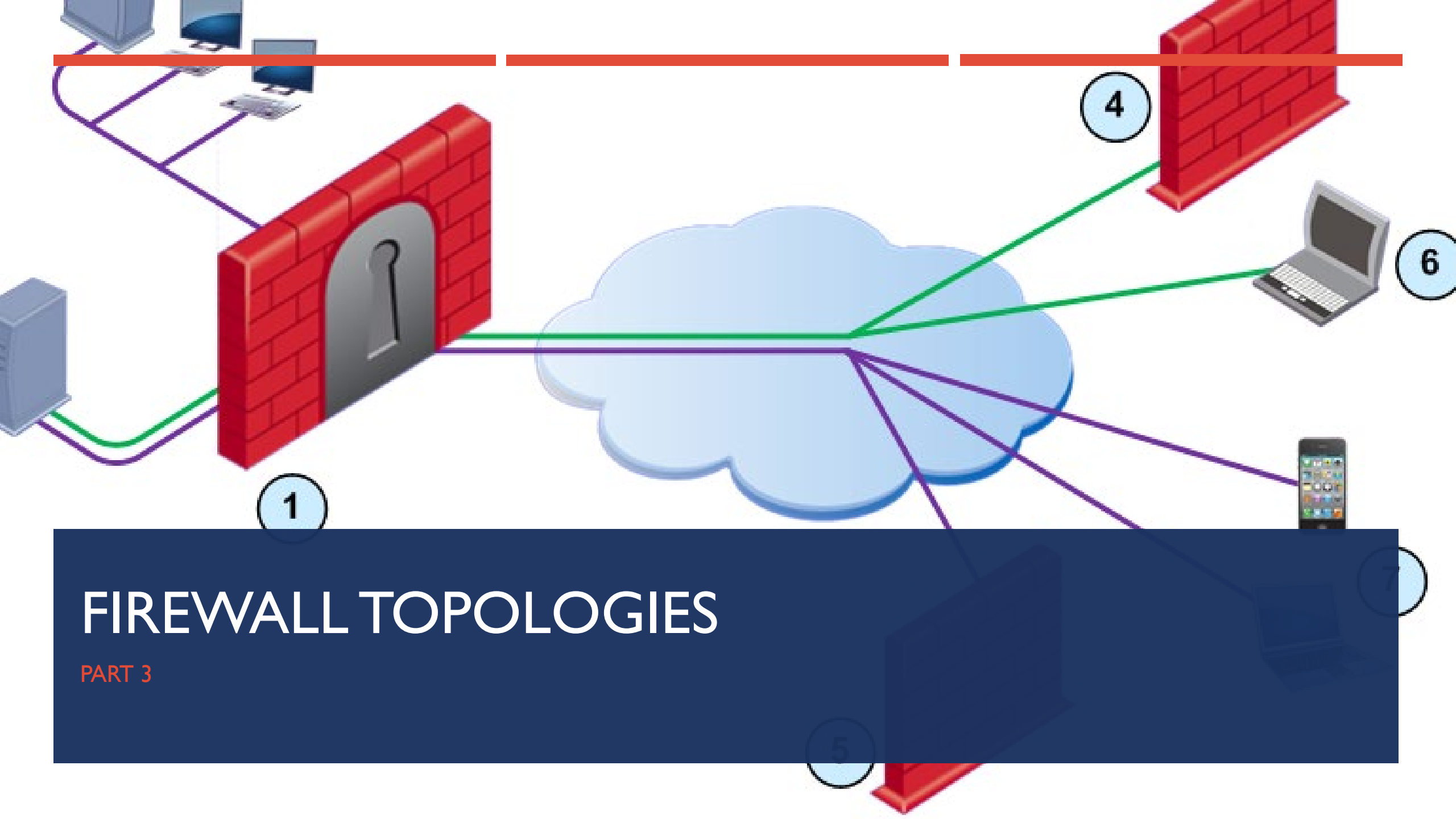
- Protect private network from outside attacks
  - Also separate departments
  - Protect connections between remote offices
- Can be used within private network
- Concentrate controls into one "choke point"
  - Like the gatehouse of a castle
- Can generate alarms when attacks are attempted
- Convenient location for other services
  - NAT
  - WWW/FTP Servers

FIREWALLS BENEFITS (CONTD.)

- DoS attack protection
  - Attack packets destined for a specific host can be stopped at the outer gateway of network
- Logging of attacks and traffic
- Blacklist maintenance
- Trace connections
  - Set maximum connections limit for single host
  - Prevents half-open connections (“SYN flood” attack)

FIREWALLS DRAWBACKS

- Cannot protect against attacks that do not go through the firewall
- Cannot guard against traitors or accidental infringements
  - Though risk can be reduced by internal firewalls between departments etc.
- People are also a weak link…
  - Security of network is only as good as weakest link - one weak host weakens entire network



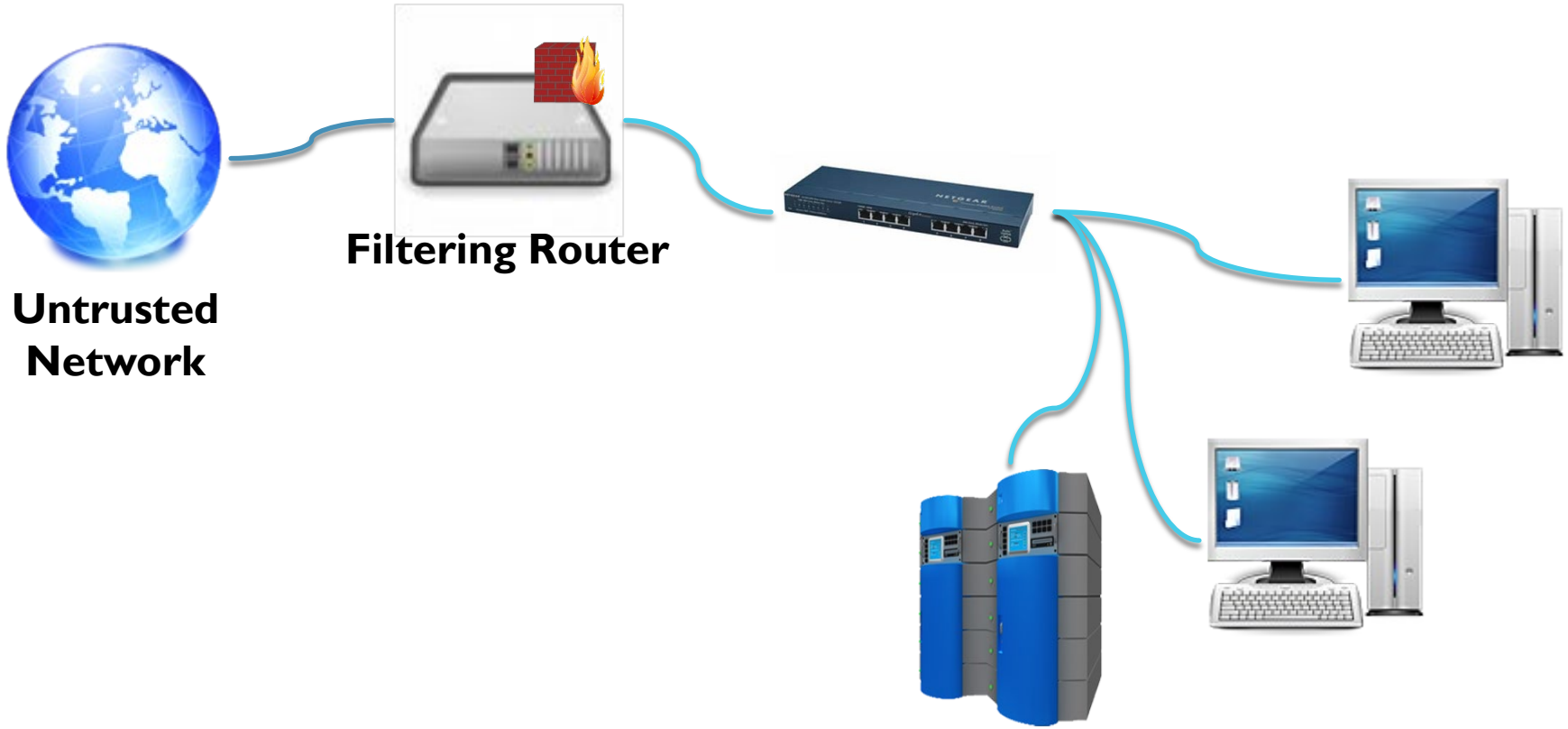
FIREWALL TOPOLOGIES

PART 3

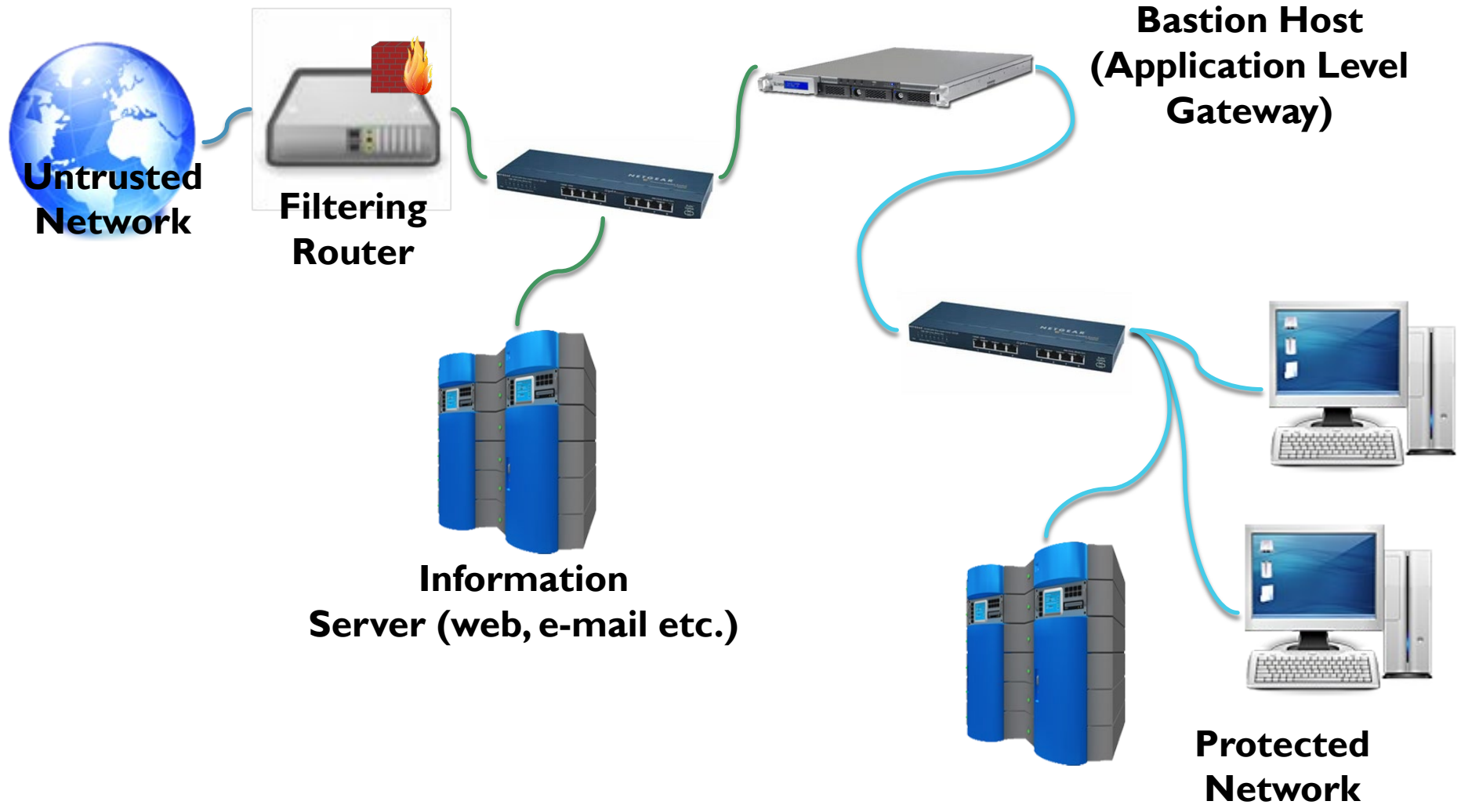
FIREWALL TOPOLOGIES

- Many different topologies
  - Have to find right balance: complexity vs. security
- Divide Organisation into zones
  - Firewall security specific to each one
- Number of decisions to be made:
  - Stance of Firewall
    - Philosophy behind the ACL/rulebase design
    - Example: "Everything not explicitly allowed is denied"
  - Overall Security Policy of Organisation
  - Financial cost of Firewall
  - Components or building blocks of the Firewall system

SIMPLEST TOPOLOGY



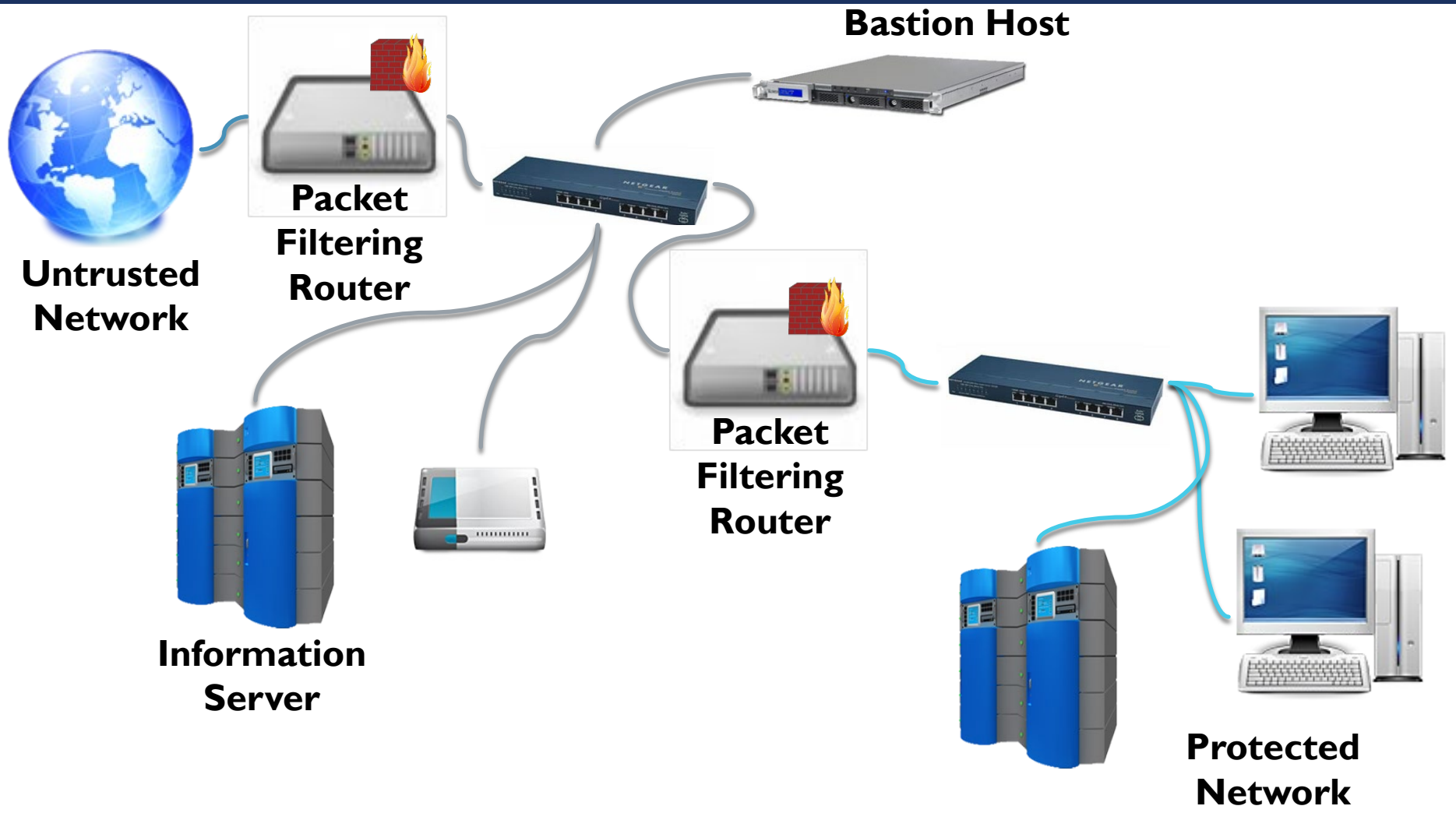
FIREWALLS - SCREENED HOST



DEMILITARIZED ZONE (DMZ)

- DMZ is a Screened-Subnet Firewall
  - Employs Two Filtering Routers
- Screened subnet typically contains…
  - The Bastion Host
  - Information Server (IS)
  - Remote Access Server (RAS)
  - Other public servers
  - Protected at both ends by the secure routers

FIREWALLS - DEMILITARISED ZONE



DMZ FIREWALLS

- Inner router will typically…
  - Allow connections to hosts in the DMZ only if started by hosts in the protected network
- Outer router will typically…
  - Allow connections to hosts in the DMZ started by hosts in the outside network
  - Allow connections to hosts in the outside network started by the Bastion host
- Anything not specifically allowed is disallowed

UNIFIED THREAT MANAGEMENT (UTM)

- A single network firewall that also contains:
  - **Spam** protection
  - **Anti-virus** capability
  - Intrusion detection system **(IDS)**
  - Web **content filtering**

- Helps Guard against "blended threats"
- Simplifies management for non-specialists
- Advanced Solution -> **SIEM**

SIEM - SECURITY INFORMATION EVENT MANAGEMENT

- Logging and Event Aggregation
  - Network (Router, Switch, Firewall etc.)
  - System (Server, Workstation etc.)
  - Application (Web, DB)

- Analyze all the above and detect relationships

- E.g.
  - Log Rhythm (http://logrhythm.com)
  - IBM Qradar (http://www.q1labs.com)

INTRUSION DETECTION SYSTEMS & INTRUSION PREVENTION SYSTEMS

- **IDS** aim - to automatically detect and identify possible security incidents

- **IPS** may have the capacity to stop incidents
  - Block access
  - Terminate connection
  - Reconfigure the security settings
  - Deleting Email attachments

IDS

- What does and IDS/IPS do when an incident is detected?

Typical functions:

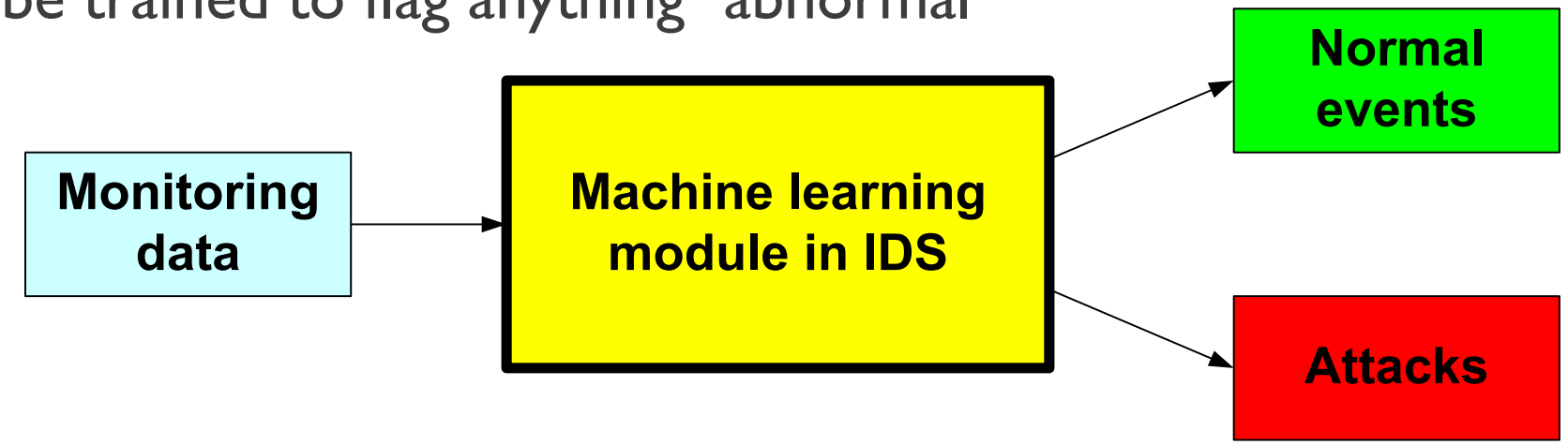
- IDS/IPS **collect/log** data about the incident
- Trigger **alerts** to the key personnel involved in the system security
- Compile **reports** that summarize the events of interest

IDS ANALYSIS

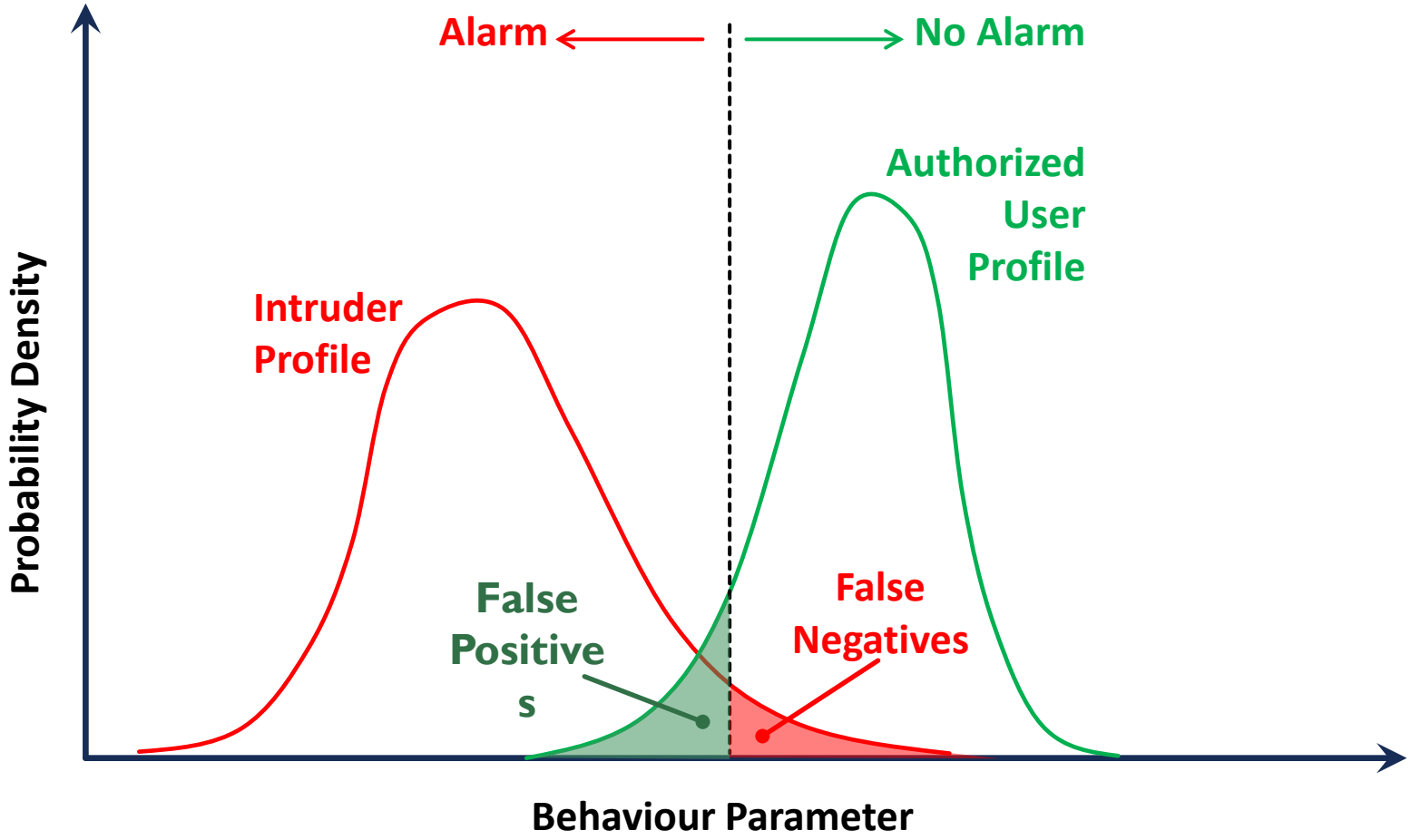
- Using **signatures of known** attacks **(Signature Based)**

or

- Using **Machine Learning (Anomaly Based)**
  - Eg: Neural Networks or K-Means Algorithm
- Could simply be trained to flag anything "abnormal"



INTRUSION DETECTION



VIRTUAL PRIVATE NETWORKS (VPN)

- Another secondary function often packaged with firewalls/routers

- **Goal:** Transmit private data across public network whilst maintaining confidentiality and authenticity
  - Encrypt TCP/IP Packets
  - Works at lower level: layer 3 (link encryption)
  - Packet encrypted before IP header added

VPN – TUNNELLING

- **Goal:** Hide source/destination IP addresses
- A feature of most routers/firewalls
- Encrypted/decrypted at tunnel ends
- **Advantages:**
  - Hides source address
  - Bypass restrictions*
- **Disadvantages:**
  - Increases packet size, therefore chance of fragmentation
  - Loss of end to end confidentiality
  - Slow

LESSONS LEARNED



FIREWALL



ACLs & PACKET FILTERING



FIREWALL TOPOLOGIES



UTM, SIEM, IDS, IPS & VPN

QUESTIONS ?




Thank
You